Secure Software Design and Development (Part I: Software Security Fundamentals)

CHAPTER 2. A RISK MANAGEMENT FRAMEWORK

BOOK: SOFTWARE SECURITY: BUILDING SECURITY IN, 1ST EDITION BY GARY MCGRAW

Software security

- We've all said it—security is risk management.

- An RMF is at its heart a philosophy for software security. Following the RMF is by definition a full lifecycle activity, no matter whether you're working on a little project or a huge corporate application strategy.

- For the purposes of this chapter, consider risk management as a high-level approach to iterative risk management that is deeply integrated throughout the software development lifecycle (SDLC) and unfolds over time.

Software security

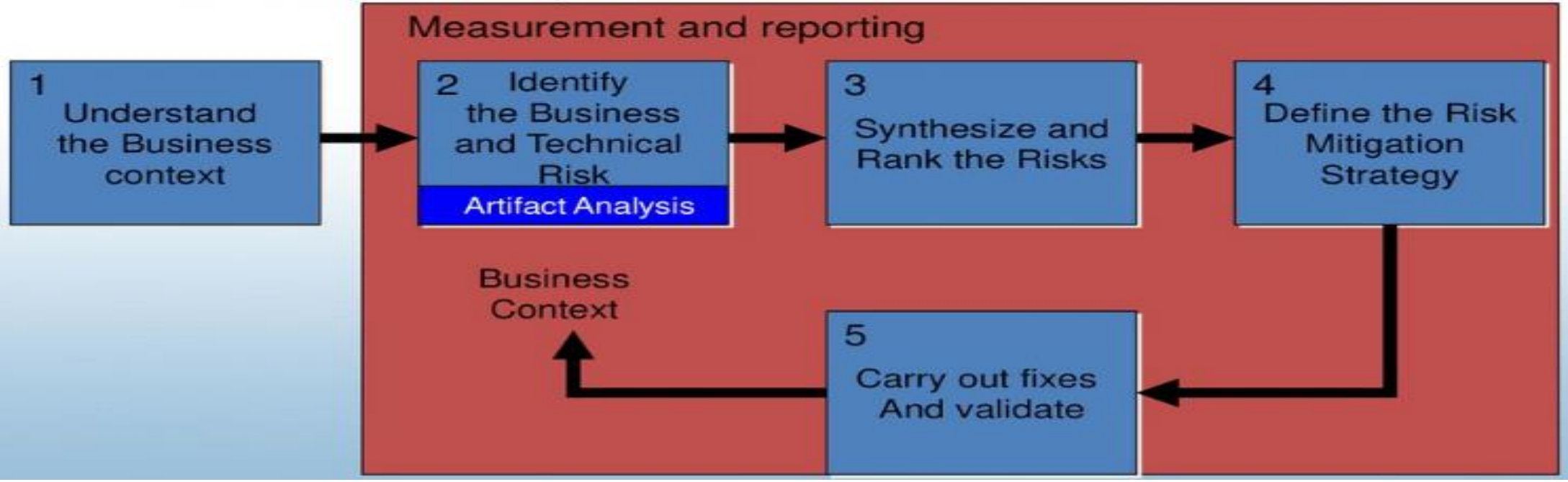
Risk Management Framework (RMF)

- Continuous risk management process
- Identify and keep track of risks overtime and a software project unfolds
- High-level approach to iterative risk management that is deeply integrated throughout the SDLC
- Identify, rank, track, and understand software security risks as it changes over time

Risk Management Framework: Five Stages

Risk Management Framework: Five Stages

- RMF occurs in parallel with SDLC activities



Risk Management Framework: Five Stages

Stage 1: Understand Business Context

- Risk management
  - Occurs in a business context
  - Affected by business motivation
- Key activity of an analyst
  - Extract and describe business goals – clearly
    - Increasing revenue; reducing dev cost; meeting SLAs; generating high return on investment (ROI)
  - Set priorities

Risk Management Framework: Five Stages

Stage 2:
Identify the Business & Technical Risks

- Business risks have impact
  - Direct financial loss; loss of reputation; violation of customer or regulatory requirements; increase in development cost
- Severity of risks
  - Should be capture in financial or project management terms
- Key is to tie technical risks to business context

Risk Management Framework: Five Stages

Stage 3: Synthesize and Rank the Risks

- Prioritize the risks alongside the business goals
- Assign risks appropriate weights for resolution
- Risk metrics
  - Risk likelihood
  - Risk impact
  - Number of risks mitigated over time

Risk Management Framework: Five Stages

Stage 4: Risk Mitigation Strategy

- Develop a coherent strategy
  - For mitigating risks
  - In cost effective manner; account for
    - Cost
    - Completeness
    - Likelihood of success
    - Implementation time
    - Impact
- A mitigation strategy should
  - Be developed within the business context
  - Must directly identify validation techniques

Risk Management Framework: Five Stages

Stage 5: Carry out Fixes and Validate

- Execute the chosen mitigation strategy
  - Rectify the artifacts
  - Measure completeness
  - Estimate
- Validate that risks have been mitigated
  - Testing can be used to demonstrate
  - Develop confidence that unacceptable risk does not remain

The RMF Is a Multilevel Loop

RMF - A Multi-loop

- Risk management is a continuous process
  - Five stages may need to be applied many times
  - Ordering may be interleaved in different ways
    - Risk can emerge at any time in SDLC
      - One way – apply in each phase of SDLC
    - Risk can be found between stages
- Level of application
  - Primary – project level
    - Each stage must capture complete project